NOTE

In the following examples, we will refer to the Cedar engine as the PDP used by ACME without specifying whether it is Amazon Verified Permissions or a locally hosted Cedar runtime, since the implementation details are not relevant to the points we are making.

11.1.1 Pattern 1: API gateway as enforcement point

The first place ACME focused on was the API gateway. It already handled every API request, whether from employees, customer apps, or other internal systems. Bob argued that the gateway should become the single policy enforcement point (PEP): the one location to normalize requests into Cedar's PARC format and consult the Cedar engine for a decision.

Carol, for example, doesn't access the HR API directly. She uses the Manager Dashboard, an internal application that collects data from HR, Finance, and the Customer Collaboration platform to give managers a single place to view their teams, budgets, and customer assignments. When Carol clicks the View Team Salaries option, the dashboard calls the HR API on her behalf.

The Manager Dashboard doesn't need to enforce authorization itself; it simply passes along verified information about Carol as the principal. The API call specifies the action (`view_salaries`) and the resource (Carol's department). The gateway intercepts the request, constructs the complete PARC authorization request, and forwards it to Cedar. Figure 11.1 illustrates how this functions.